

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes to audit risk levels from recent revalidation
April 2025	All	All	Jessica Lin	Renamed the organization from Corporate Health and Safety to Enterprise Health. Changed Global Privacy Assessment to Privacy Impact Assessment. Updated links and self-service reporting
April 2024	Planning	Self-Service Report and Fraud Template	Jessica Lin	Added Self-Service Report (WWBCIT), updated links and proper nouns
April 2023	Data Protection	OT002.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment.....	4
PLANNING: Data Analysis.....	5
PLANNING: Reference Material	6
PLANNING: Self-Service Report.....	7
PLANNING: Fraud Template.....	8
CONTROL ASSESSMENT QUESTIONS	9
Key Control Question: 1. Medical Clinical Services.....	9
Primary Test: Medical Services (MC001.P)	10
Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes	11
Primary Test: Compliance with Laws and Regulations (OT001.P)	12
Primary Test: Data Protection (OT002.P).....	13

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

PROCESS AND OBJECTIVE

This revised audit program focuses on the IBM locations globally that still are required to offer medical/clinical services to their employees. Medical / Clinical services is defined as a physical facility where certified medical profession(s) provide medical or clinical service to IBM employees. The specific focus is to determine that there was a management process in place to monitor medical services provided to IBM employees and ensure that these services were consistent with IBM and local regulatory requirements.

The portions of this program that used to focus on the facility and industrial hygiene aspects of our manufacturing and research facilities have been moved over to areas that would better capture the activity. Specifically, there are Global Real Estate (GRE), In-House Manufacturing, Site Security and Overview audits. This was the outcome of an exercise involving representatives of all of the areas listed above and finally agreed to in 1Q 2015.

The common tests that have been either moved or deleted from the original audit program are:

Common Test Name	Status
Occupational Illness and Injury Management (SP001.P)	Deleted – 3 rd party audits (OSHA, VPP, OSHA 18001) include this review
Fire and Life Safety (SP002.P)	Incorporated into GRE
Equipment/Process Installation (SP003.P)	Incorporated into GRE, Manufacturing and Overview for Research Locations
Contractor Safety (SP004.P)	Deleted – Covered under procurement
Building Maintenance Operations (SP005.P)	Incorporated into GRE
Potentially Hazardous Work Activity (SP006.P)	Incorporated into GRE, Manufacturing and Overview for Research Locations
Safety Training (SP008.P)	Incorporated into GRE, Manufacturing and Overview for Research Locations
Manuals/Materials Handling (SP009.P)	Incorporated into GRE, Manufacturing and Overview for Research Locations
Communications, Monitoring, Assessments (SP010.P)	Deleted – 3 rd party audits (OSHA, VPP, OSHA 18001) include this review
Emergency Response (SP011.P)	Incorporated into Site Security
Driving/Transportation (SP012.P)	Deleted - NA
Facility Operations (SP013.P)	Deleted – Duplicate of GRE audit program
Occupational Illness and Injury Management (IH001.P)	Deleted – 3 rd party audits (OSHA, VPP, OSHA 18001) include this review
Ventilation (IH002.P)	Incorporated into GRE
Confined Spaces (IH003.P)	Incorporated into GRE
Asbestos (IH004.P)	Incorporated into GRE

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

PLANNING: Audit Program Risk Alignment

Medical Clinic Services

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Data Privacy, Security, and Protection	High	Other: Use for all Aspects of HR Primary and Business Processes	OT002.P
Compliance with Local Laws	High	Other: Use for all Aspects of HR Primary and Business Processes	OT001.P
Medical Staff Certification and Vendor Management	Medium	Medical Clinical Services	MC001.P
Facility Control of Pharmaceuticals	Low	Medical Clinical Services	MC001.P

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
All currently applicable IBM approved, and government approved deviations, exceptions, or risk acceptances for medical requirements	Understand the nature of the exception and ensure that the proper reviews and approvals have taken place prior to the deviation/exception	Fast tracking of the request proper reviews and approval. Proper senior level visibility to the issue and lack of proper review	Unapproved deviations from IBM and/or government standards could lead to reviews, fines and even closure of the facilities
Copies of contracts, including scope of work, with any suppliers providing medical services, including an organization chart if the supplier is resident at the location	Review that the vendor is qualified to perform the T&Cs of the contract, and that we are receiving the products/services as stated in the contract	Vendor did not go through the RFP/RFS process. Vendor may not be an approved IBM vendor. Vendor does not meet the qualifications required to provide the product/services.	Unapproved vendors may not be qualified to provide the specific products and/or services required by IBM. Also, there could be fraud in the selection process.

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

PLANNING: Reference Material

More specific references are listed with each test. This list includes the primary references and associated intranet addresses.

Corporate Instructions, Human Resources (HR)110 IBM Health and Safety Responsibilities
<https://w3.ibm.com/w3publisher/corporate-documents/hr/hr-110>

Corporate Instructions, HR 113 Protection of Employee Information
<https://w3.ibm.com/ibm/corporate-documents/hr/hr-113>

Guidelines and Supporting Documentation for the Protection of Employee Information
<https://w3.ibm.com/ibm/corporate-documents/hr/hr-guidelines>

Corporate Policy 127 IBM's Culture of Health and Safety
<https://w3.ibm.com/w3publisher/corporate-documents/corporate-directives/corporate-policies/cp-127>

IBM Health & Safety Standards – Clinical Services
<https://ibm.ent.box.com/s/dnqgqe0gk6uengkrvwd35zhom4jhen62>

Privacy@IBM
<https://w3.ibm.com/ibm/privacy/>

Corporate Assurance and Advisory Services
<https://w3.ibm.com/w3publisher/audit-a2-0-ibm/our-services/assurance-reviews-and-advisory-services>

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

PLANNING: Self-Service Report

Some relevant information in audits will now be extracted directly by the audit team. These are as follows:

Information previously in IDR	Instructional materials to download information
Management Self-Assessment of Controls (MSAC) Risk Evaluations (RE's) Proactive Business Control Reviews (No key controls)	WorldWide Business Controls Integrated Toolset (WWBCIT) is being replaced by Finance Business Controls OpenPages in 1Q 2025. For the data prior to 1Q 2025: Option 1: Login to WWBCIT. In the left side menu, select "Manage self assessment," "Risk evaluations," or "Proactive process review," and then select the applicable criteria to get the results. Option 2: Login to WWBCIT Cognos reports Select "BCIT406 – Management Self Assessment Trending Report" or Select "BCIT211 – Risk Evaluation Report" or Select "BCITLL – Lessons Learned Detail Report," and then select the applicable criteria to get the results. For the data starting from 1Q 2025: Login to OpenPages, change the profile to "FBC General User". Select the applicable process from the primary menu on the top left for all process related materials. On the home page, select the report and export it with applicable criteria. Note: Business Unit: Human Resources Reported (global) process: Medical Clinic Services (MCS) Controllable Unit SubCategory: MCS

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Falsification of receipt of the goods and services required in the contract. In addition, the falsification of the qualifications of the vendors	Routine management reviews of the Medical Clinic process, including any required documents as to the qualifications of the vendor	Get a universe of the contracts of the vendors supporting Clinical Services at the location in question: Request to see proof of receipt of goods and services Request any information relating to the qualification of the vendor to perform the work agreed to in the contract

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Medical Clinical Services

Objective:

To determine that there was a management process to monitor medical services consistent with IBM and regulatory requirements.

Reference Information

IBM Health & Safety Standards – Clinical Services

<https://ibm.ent.box.com/s/dnqgqe0gk6uengkrvwd35zhom4jhen62>

IBM Worldwide Records Management Plan (sunset at February 28, 2025)

<https://w3.ibm.com/w3publisher/enterprise-data-governance/wrm>

Enterprise Data Governance & Standards

<https://w3.ibm.com/w3publisher/data-governance-standards>

Risk/Exposure:

Lack of a process to review and monitor the qualifications, certifications and performance of employees, vendors and/or contractors providing medical services could result in IBM employees receiving sub-standard or below the required care. This could result in dissatisfied employees, medical malpractice, and legal action against IBM.

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Medical Clinical Services

Primary Test: Medical Services (MC001.P)

Objective:

To determine that there was a management process to monitor medical services consistent with IBM and regulatory requirements.

Reference Information

IBM Health & Safety Standards – Clinical Services

<https://ibm.ent.box.com/s/dnqgqe0gk6uengkrvwd35zhom4jhen62>

IBM Worldwide Records Management Plan (sunset at February 28, 2025)

<https://w3.ibm.com/w3publisher/enterprise-data-governance/wrm>

Enterprise Data Governance & Standards

<https://w3.ibm.com/w3publisher/data-governance-standards>

Approach:

Review the medical programs and related documentation:

1. Do Enterprise Health units and health care professionals have up-to-date licenses, registrations and certifications as required by law?
2. Where Enterprise Health provides clinical services, is the facility designed for medical services?
3. Is the clinic equipped with emergency medications, supplies, and suitable equipment, as determined by local regulations available?
4. Are there documented processes, which meet all local legislation, covering:
 - a. License, registration, certification of medical personnel.
 - b. Health Information Management -- Individual's health information obtained in the course of performing medical services must be handled confidentially and be collected, used, disclosed, stored, accessed, and transferred in accordance with legal requirements.
 - c. Contracted Medical Clinic Services
 - d. Occupational Health Examination – the process executed inside the clinic by the clinic staff. The process must incorporate the local requirements.
 - e. Pharmacy Control - The process must address the review and documentation of contents (medication, medical equipment, and supplies); security from inappropriate access and use; and safe administration, and disposal.
 - f. Infection Controls - The process must address treatment of all blood, and other potentially infectious material, with the assumption they are contaminated with blood borne pathogens, and include vaccination, universal precautions, hygiene measures, required personal protective equipment (PPE), recommendations for immunizations, and post exposure measures.

MEDICAL CLINIC SERVICES AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Objective:

Data protection: Check data privacy, including how personal information (PI) and sensitive personal information (SPI) is handled among or between IBM and third-party vendors involved.

Risk/Exposure:

See risks noted in each test.

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Compliance with Laws and Regulations (OT001.P)

Objective:

IBM must fully comply with applicable laws and regulations. Determine whether process design and execution comply with laws and regulations.

Risk or Exposure:

Failure to comply with applicable laws and regulations could expose IBM to risk of litigation and harm IBM's image.

Approach:

Speak with IBM human resources and legal personnel to identify what laws and regulations could apply. Discuss how to apply this knowledge to the audit field work. Be prepared to review findings with legal personnel if needed.

Regulations could address topics such as:

- Medical services required to be performed within the on-site clinic.
- Retaining records to confirm process execution.

During audit preparation and field work, keep this topic in mind for any scope area that is considered or is tested.

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT002.P)

Objective:

This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect personal information (PI) and sensitive personal information (SPI).

Risk or Exposure:

Failure to comply with applicable laws and regulations may include fines or penalties.

Approach:

Consider ways that PI and SPI could be compromised. Test for the protection of PI and SPI information for anyone involved in performing process steps. This includes IBM employees, contractors, and vendors.

- Access to data and applications (including granting, periodic revalidating, and revoking).
- Separation of duties.
- File transfers among IBM and vendors, including encryption and classification.

Privacy and Data Protection requirements:

- Review the Privacy and Data protection requirements:
 - Whether personal information and sensitive personal information can be handled by third parties or handled by anyone outside the country.
 - When it is or is not appropriate to share personal information and sensitive personal information
- Was a Privacy Impact Assessment (PIA) completed?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

MEDICAL CLINIC SERVICES

AUDIT PROGRAM #40-80-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Other: Use for all Aspects of HR Primary and Business Processes

Primary Test: Data Protection (OT002.P)

(Continued)

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of PIAs for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.